

Отчёт по учебной практике

Исследование уязвимости SSTI

Выполнил: Аньшин Сергей, группа ИСП 406

Тема и цель работы

Тема: исследование уязвимости SSTI (Server-Side Template Injection) в учебных веб-приложениях на Python/Flask/Jinja2 и PHP/Twig.

Цель: проверить обработку пользовательского GET-параметра book, подтвердить выполнение шаблонных выражений и сравнить результаты двух шаблонизаторов.

Краткие теоретические сведения

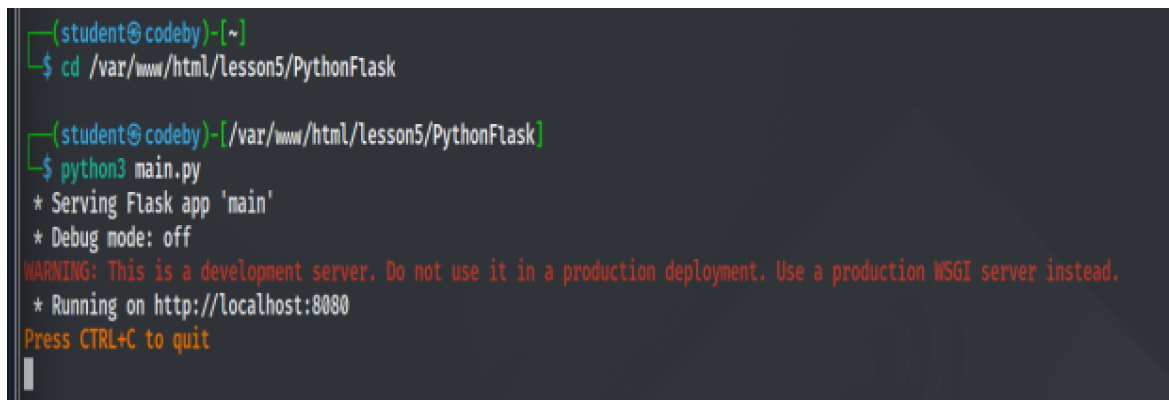
SSTI — внедрение шаблонных выражений на стороне сервера. Оно возникает, когда введённые пользователем данные попадают в шаблон как исполняемый фрагмент, а не выводятся как обычный текст. Признак в этой работе — вычисление арифметического выражения `{{7*7}}` с результатом 49.

Шаблонизаторы Jinja2 и Twig используют похожую запись выражений, но различаются обработкой умножения числа на строку: для `{{7*7}}` Jinja2 повторяет строку и выдаёт 7777777, а Twig преобразует строку к числу и выдаёт 49. Проверки выполнены в учебной среде на localhost.

Ход работы

Часть 1. Python Flask и Jinja2

Приложение запущено из каталога `/var/www/html/lesson5/PythonFlask` командой `python3 main.py`. Сервер сообщил об адресе `http://localhost:8080`.



```
(student@codeby)~[~]
$ cd /var/www/html/lesson5/PythonFlask

(student@codeby)~/var/www/html/lesson5/PythonFlask
$ python3 main.py
* Serving Flask app 'main'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on http://localhost:8080
Press CTRL+C to quit
```

Рисунок 1 — Запуск учебного приложения Flask на порту 8080

После открытия localhost:8080 отобразилась главная страница Python Web App. Выбор книги «Портрет Дориана Грея» установил значение book=doriangray и открыл описание.

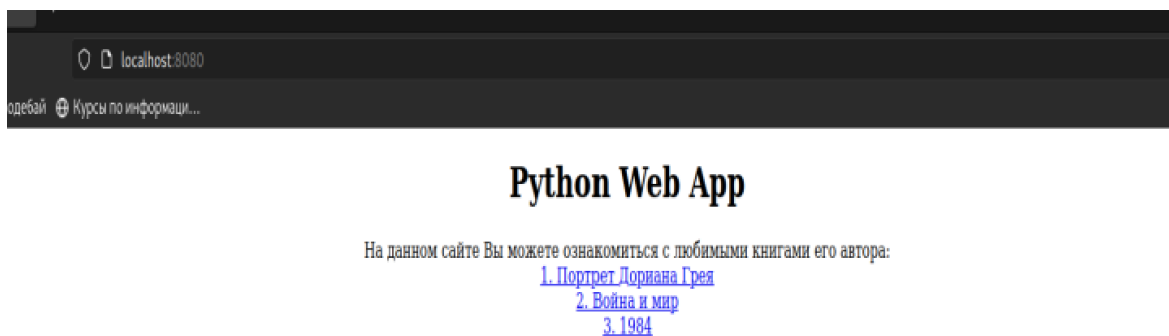


Рисунок 2 — Главная страница Python Web App

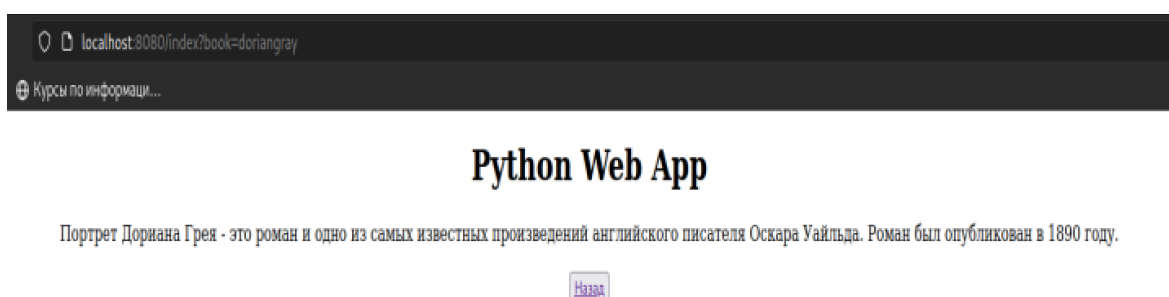


Рисунок 3 — Описание книги при book=doriangray

Для проверки ввода значение параметра заменено на 123. Приложение отразило его в сообщении об отсутствии описания. Затем введено $\{7*7\}$: выражение сохранилось в ответе без вычисления.



Рисунок 4 — Отображение пользовательского значения book=123



Рисунок 5 — Проверка $\{7*7\}$: выражение не вычислено

При проверке выражения в двойных фигурных скобках сервер вычислил 7×7 и вывел 49. На скриншоте перед результатом остаётся символ \$, введённый перед выражением; он не участвует в вычислении.

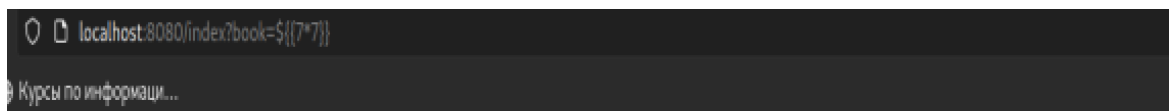


Рисунок 6 — Проверка `{{7*7}}`: вычислено значение 49

Проверка `{{7*'7'}}` дала 7777777: строка «7» повторилась семь раз. Такое поведение соответствует Jinja2, что согласуется с используемым Python-приложением.

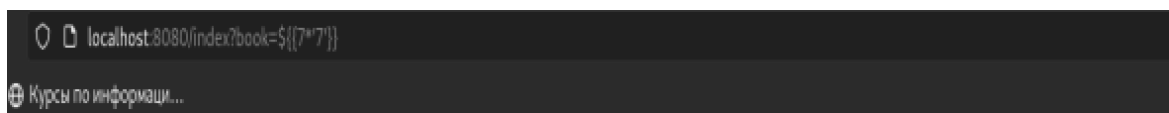
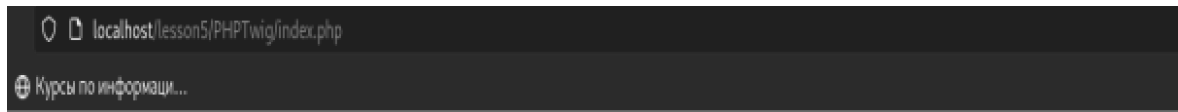


Рисунок 7 — Проверка `{{7*'7'}}`: строка повторена семь раз

Часть 2. PHP и Twig

В браузере открыта страница `http://localhost/lesson5/PHPTwig/index.php`. При `book=123` приложение вывело переданное значение в сообщении об отсутствии книги.



PHP Web App

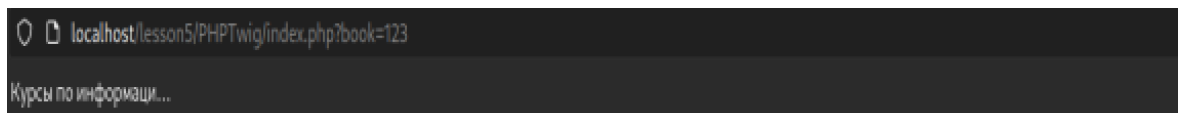
На данном сайте Вы можете ознакомиться с любимыми книгами его автора:

[1. Портрет Дориана Грея](#)

[2. Война и мир](#)

[3. 1984](#)

Рисунок 8 — Главная страница PHP Web App



PHP Web App

На данном сайте Вы можете ознакомиться с любимыми книгами его автора:

[1. Портрет Дориана Грея](#)

[2. Война и мир](#)

[3. 1984](#)

К сожалению, описания для книги 123 у нас на сайте нет :(

Рисунок 9 — Отображение пользовательского значения `book=123`

Выражение $\{7*7\}$ отобразилось без вычисления. Проверка выражения в двойных фигурных скобках дала 49; ведущий символ \$ на снимке сохранился как обычный текст.



PHP Web App

На данном сайте Вы можете ознакомиться с любимыми книгами его автора:

- [1. Портрет Дориана Грея](#)
- [2. Война и мир](#)
- [3. 1984](#)

К сожалению, описания для книги $\{7*7\}$ у нас на сайте нет :(

Рисунок 10 — Проверка $\{7*7\}$: выражение не вычислено



PHP Web App

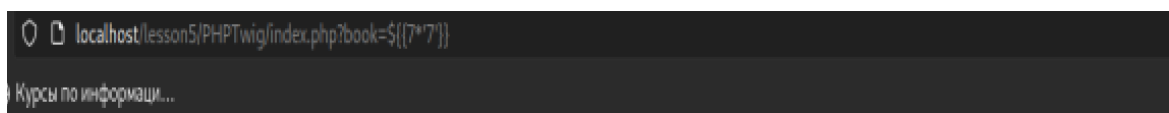
На данном сайте Вы можете ознакомиться с любимыми книгами его автора:

- [1. Портрет Дориана Грея](#)
- [2. Война и мир](#)
- [3. 1984](#)

К сожалению, описания для книги \$49 у нас на сайте нет :(

Рисунок 11 — Проверка $\{\{7*7\}\}$: вычислено значение 49

Выражение `{{7*7}}` в PHP-приложении также дало 49. В отличие от Jinja2, повторения строки не произошло. Этот результат соответствует Twig, указанному для данного учебного приложения в методичке.



PHP Web App

На данном сайте Вы можете ознакомиться с любимыми книгами его автора:

[1. Портрет Дориана Грея](#)

[2. Война и мир](#)

[3. 1984](#)

К сожалению, описания для книги \$49 у нас на сайте нет :(

Рисунок 12 — Проверка `{{7*7}}`: получено значение 49

Вывод

В обеих частях работы значение параметра book влияло на ответ сервера, а выражение `{{7*7}}` вычислялось до 49. Это подтверждает SSTI в исследованных учебных точках входа. Проба `{{7*7}}` позволила различить шаблонизаторы: Jinja2 вернул 7777777, Twig — 49. Другие способы эксплуатации в данной работе не выполнялись.

Источник: учебная методичка «5. SSTI (2).pdf»; иллюстрации — скриншоты выполнения практики.